

Audit Tecnico Completo

Audit del programma eseguito il 30 aprile 2026 sul repository operativo Next.js + Supabase. Focus: sicurezza, multi-tenant, qualità eseguibile e aderenza alla Definition of Done.

ESITO TEST

138 / 138 OK

LINT

2 warning

BUILD

Non certificato

Stato sintetico: il progetto ha una base concreta e una copertura test incoraggiante, ma oggi non può essere considerato pienamente "beta vendibile" senza correggere alcuni rischi strutturali, soprattutto su reset password, selezione tenant e gestione del materiale legacy nel repository.

Findings Principali

HIGH

Reset password fragile e insicuro

L'endpoint `app/api/auth/reset-password/route.ts` cambia subito la password dell'utente e poi prova a inviarla via email in chiaro. Se l'invio fallisce, l'account resta comunque alterato e l'utente può rimanere bloccato.

- Riferimento principale: `app/api/auth/reset-password/route.ts:77`.
- Invio credenziale temporanea in plain text: `lib/server/password-reset-email.ts:82`.
- Impatto: rischio logout, cattiva UX e modello di recovery non allineato a una beta commerciale.
- Priorità: sostituire con link di recovery one-time e invalidazione controllata.

HIGH

Risoluzione tenant hardcoded e multi-tenant non rigoroso

La logica di scelta del tenant attivo usa un `PRIMARY_TENANT_ID` fisso. Questo introduce il rischio che utenti con più membership operino sul tenant sbagliato nelle route server-side che lavorano con `service_role`.

- Costante hardcoded: `lib/tenant-preference.ts:3`.
- Uso nel path di autorizzazione: `lib/server/pricing-auth.ts:56`.
- Impatto: possibile mismatch tenant in letture e scritture protette.
- Priorità: tenant esplicito per request o contesto sessione persistito per utente.

MEDIUM

Materiale legacy e backup versionati nel repository

Nel repo risultano tracciati file come `server/prisma/dev.db` e vari backup in `server/backups/`, nonostante l'area legacy sia dichiarata read-only e fuori dallo stack ufficiale.

- Contrasto con policy locale: `AGENTS.md:11`.
- Cartelle dichiarate legacy: `server/LEGACY_READONLY.md`, `client/LEGACY_READONLY.md`.
- Impatto: rischio dati sensibili, confusione architetturale e repository più pesante.
- Priorità: rimuovere i dump dal versionamento e tenerli fuori dal perimetro operativo.

MEDIUM

Endpoint tenant-data troppo pesante

`app/api/ops/tenant-data/route.ts` restituisce dataset completi del tenant con più `select("*")`, compresi servizi, eventi, hotel e opzionalmente inbound emails.

- Riferimento: `app/api/ops/tenant-data/route.ts:7`.
- Impatto: payload ampi, latency crescente e stress inutile lato browser/server.
- Priorità: endpoint specializzati, filtri, projection fields e paginazione reale.

LOW

OTP generato con random non crittografico

Il codice OTP viene generato con `Math.random()`, soluzione debole per un fattore di autenticazione.

- Riferimento: `lib/server/otp-utils.ts:1`.

- **Uso nel flusso:** `app/api/auth/otp/send/route.ts` e `app/api/auth/otp/verify/route.ts`.
- **Priorità:** passare a `crypto.randomInt` e, se possibile, hashare il codice a database.

LOW

Deriva operativa nella gestione degli env locali

La regola di progetto richiede solo `.env.local`, ma nel workspace è presente anche `.env`.

- **Regola dichiarata:** `AGENTS.md:12`.
- **Git ignore permissivo:** `.gitignore:3`.
- **Impatto:** rischio operativo, non leak confermato nel repository.

Verifica Eseguita

CHECK	ESITO	NOTE
<code>pnpm.cmd</code> <code>test</code>	OK	14 test files, 138 test superati.
<code>pnpm.cmd</code> <code>lint</code>	WARNING	2 warning residui, quindi la DoD "lint ok" non è ancora pienamente chiusa.
<code>pnpm.cmd</code> <code>build</code>	BLOCCATO	Build non certificato: Next ha segnalato un altro processo/build state già attivo in <code>.next</code> .

Nota: il mancato esito finale del build non equivale a bug applicativo provato, ma oggi impedisce di dichiarare la voce "`pnpm build ok`" come soddisfatta.

Valutazione Finale

La piattaforma è già ampia, concreta e con segnali positivi sul fronte test e copertura funzionale. Però la beta ha ancora alcuni difetti strutturali che pesano più dei warning cosmetici.

- Pronto per continuare l'hardening: sì.
- Pronto per demo commerciale guidata: sì, con cautela.
- Pronto per dichiararlo "vendibile" senza riserve: non ancora.

Le tre correzioni prioritarie sono:

- rifare il reset password con recovery link;
- eliminare la risoluzione tenant hardcoded;
- ripulire i backup/database legacy dal repository operativo.